COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.1 · Secure Baselines

Mestre CyberSec · **Aula 4.1 — Secure Baselines** (4:11) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

> **Resumo Executivo da Aula:** Baseline = config PADRÃO que toda máquina tem: imagem gold (CIS hardened), patch automático, MFA, EDR. Deploy automatizado: GPO, Intune, Ansible, SCCM — NUNCA manual.

💡 Highlights que a prova CompTIA cobra

- Baseline: o mínimo de config que toda máquina segue
- Deploy automatizado (GPO/Intune): nunca manual

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'baseline configuration applied to all workstations'=secure baseline

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.1 — Secure Baselines)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Linha de Base Segura (N/A)

Configuração mínima de segurança documentada e padronizada aplicada a todos os sistemas de um grupo, geralmente incluindo ajustes endurecidos, patches, MFA e EDR. Garante consistência e reduz a superfície de ataque.

⚠ ***Armadilha CompTIA:*** *Se a questão falar em 'baseline configuration applied to all workstations' ou 'standard security configuration', a resposta é secure baseline.*

• Imagem Gold de Referência (N/A)

Imagem mestra de SO/software pré-configurada conforme a linha de base segura e usada para implantar novos sistemas de forma consistente. Geralmente é endurecida com benchmarks CIS antes da clonagem.

⚠ ***Armadilha CompTIA:*** *Gold image = modelo padronizado; não confunda com backup. É a fonte para implantação automatizada.*

• Endurecimento do Sistema (N/A)

Processo de proteger um sistema reduzindo sua superfície de ataque, como desativar serviços, portas e contas não usados e aplicar configurações seguras. É parte essencial da criação de uma linha de base segura.

⚠ ***Armadilha CompTIA:*** *Hardening não é só patch; envolve remover/desabilitar o que não é necessário. CIS benchmarks fornecem guias de hardening.*

• Benchmarks CIS

Diretrizes prescritivas e baseadas em consenso do Center for Internet Security, usadas para endurecer SOs, aplicações e ambientes de nuvem. Ajudam a definir configurações de linha de base segura.

⚠ ***Armadilha CompTIA:*** *CIS = benchmark de hardening reconhecido. Se a questão citar 'hardened image' ou 'industry-standard secure configuration', pense em CIS.*

• Objeto de Diretiva de Grupo (GPO)

Recurso do Microsoft Active Directory usado para implantar e aplicar centralmente configurações de segurança, incluindo linhas de base seguras, em sistemas Windows ingressados no domínio. Automatiza configuração em escala.

⚠ ***Armadilha CompTIA:*** *GPO é para ambiente Windows/Active Directory. Se a questão pede implantação automatizada de baseline em domínio, escolha GPO.*

• Microsoft Intune

Serviço de gerenciamento de endpoints e dispositivos móveis (MDM) baseado em nuvem usado para implantar linhas de base de segurança, políticas e aplicativos em dispositivos Windows, macOS, iOS e Android. Suporta aplicação automatizada e remota de baseline.

⚠ ***Armadilha CompTIA:*** *Intune = gerenciamento moderno em nuvem; GPO = tradicional on-premises AD. Escolha Intune para dispositivos não domínio/nuvem.*

• System Center Configuration Manager (SCCM)

Ferramenta de gerenciamento local da Microsoft, agora Microsoft Endpoint Configuration Manager, para implantar software, patches e configurações de conformidade em grandes ambientes Windows. Pode distribuir linhas de base seguras e aplicar configuração.

⚠ ***Armadilha CompTIA:*** *SCCM/MECM = gerenciamento on-premises de grandes frotas Windows. Distinga de Intune (nuvem) e GPO (políticas de domínio).*

• Ansible (N/A)

Ferramenta de automação de código aberto usada para gerenciamento de configuração, implantação de aplicativos e orquestração. Pode aplicar linhas de base seguras em servidores e dispositivos de rede usando playbooks, geralmente sem agente via SSH.

⚠ ***Armadilha CompTIA:*** *Ansible = automação agentless e playbooks; não é ferramenta Microsoft. Se a questão citar automação multi-plataforma/Linux, pense em Ansible.*

🏛 Visão Didática, Analogias & Análise de Governança (GRC)

📌 Linha de Base de Segurança e Imagem Dourada (Secure Baseline & Gold Image)

🏠 **Analogia Intuitiva:** Pense em uma construtora erguendo um condomínio de 500 apartamentos idênticos. Em vez de deixar cada morador instalar sua própria fiação elétrica amadora e escolher qualquer fechadura frágil, a construtora cria um 'apartamento modelo' perfeito, com fechaduras biométricas testadas, disjuntores antichamas e extintores aprovados pelos bombeiros. Essa planta aprovada é clonada exatamente igual para todos os 500 imóveis antes da entrega das chaves.

🔍 **Causa Raiz / Por que foi criado:** A configuração manual de computadores por diferentes técnicos gera inconsistências graves (desvios de configuração), portas abertas esquecidas e ausência de patches críticos, multiplicando as portas de entrada para invasores.

🛡 **Visão do Auditor de GRC:** O auditor de GRC exige a existência de um repositório centralizado e versionado de imagens-mestre (Golden Images), revisões formais de integridade a cada trimestre e a proibição estrita de instalações manuais despadronizadas sem aprovação do comitê de controle de mudanças (Change Advisory Board).

⚠ **Como cai na Prova CompTIA:** Gatilho de prova: 'Standardized minimal secure configuration deployed across all enterprise endpoints' = Secure Baseline / Golden Image. Pegadinha: tentar configurar manualmente cada máquina isolada viola a padronização e escalabilidade corporativa.

📌 CIS Benchmarks e Guias de Hardening da Indústria (CIS Benchmarks & Industry Hardening Guides)

🏠 **Analogia Intuitiva:** É o manual oficial do corpo de bombeiros e o código de obras da cidade. Nenhum engenheiro precisa adivinhar qual a largura ideal da escada de emergência contra incêndios; ele segue o manual internacional elaborado e testado exaustivamente por especialistas do mundo todo.

🔍 **Causa Raiz / Por que foi criado:** Sistemas operacionais comerciais saem de fábrica voltados para a conveniência do usuário doméstico, com dezenas de serviços inseguros e compartilhamentos ativados por padrão que se tornam vulnerabilidades imediatas em redes corporativas.

🛡 **Visão do Auditor de GRC:** O auditor verifica se a organização adotou formalmente um padrão reconhecido (CIS Level 1 para uso geral corporativo ou CIS Level 2 para ambientes de alta segurança e dados confidenciais) ou os STIGs do Departamento de Defesa americano (DISA STIGs).

⚠ **Como cai na Prova CompTIA:** Gatilho de prova: 'Consensus-based, vendor-agnostic security configuration guidelines' = CIS Benchmarks. 'Department of Defense technical implementation guides' = DISA STIGs.

📌 Políticas de Grupo e Gerenciamento Centralizado (GPO & Configuration Management)

🏠 **Analogia Intuitiva:** O painel elétrico central e o sistema de interfonia do síndico que permite trancar todas as entradas do edifício pontualmente às 22h com um único interruptor mestre, sem depender de bater na porta de cada morador pedindo para ele passar a chave.

🔍 **Causa Raiz / Por que foi criado:** Em redes com milhares de terminais de trabalho, é operacionalmente impossível manter a conformidade de segurança se a aplicação de políticas depender de técnicos configurando máquinas individualmente.

🛡️ **Visão do Auditor de GRC:** O auditor fiscaliza se as GPOs (Group Policy Objects) ou ferramentas de MDM/Intune bloqueiam privilégios administrativos locais dos colaboradores, forçam o bloqueio de tela por inatividade e impedem a desativação de antivírus e firewalls de host.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'Centralized administrative tool to enforce password complexity, screen lockouts, and registry hardening across domain endpoints' = Group Policy Object (GPO) / Configuration Management.

📌 Desvio de Configuração e Correção Automática (Configuration Drift & Desired State Configuration)

🏠 **Analogia Intuitiva:** As alterações não autorizadas que moradores fazem no apartamento ao longo dos anos — como furar vigas estruturais ou trocar fiações elétricas sem autorização. Se o condomínio não fizer vistorias periódicas para restaurar o padrão original, o prédio inteiro corre risco de curto-circuito.

🔍 **Causa Raiz / Por que foi criado:** Com o passar dos meses, técnicos de suporte alteram parâmetros temporários para solucionar emergências e esquecem de revertê-los, fazendo o sistema se afastar lentamente do seu estado seguro homologado.

🛡️ **Visão do Auditor de GRC:** O auditor requer relatórios periódicos de conformidade de configuração (compliance scans) que comparem a configuração atual com a linha de base cadastrada, utilizando ferramentas automatizadas (Ansible, Puppet, Desired State Configuration).

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'Systems gradually deviating from their secure baseline over time due to ad-hoc modifications' = Configuration drift. 'Automated restoration of systems to their approved baseline state' = Desired State Configuration (DSC).

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Configuração mínima homologada e obrigatória aplicada a todas as novas máquinas antes da entrega	**Linha de Base de Segurança (Secure Baseline / Golden Image)**
Guias neutros de configuração de segurança desenvolvidos por consenso global na indústria	**CIS Benchmarks**
Mecanismo central do Windows para impor políticas de segurança, bloqueio de tela e senhas em lote	**GPO (Group Policy Object)**
Divergência progressiva entre a configuração real de um servidor e a baseline aprovada após meses de uso	**Desvio de Configuração (Configuration Drift)**
Tecnologia de infraestrutura que força automaticamente servidores a retornarem à configuração padrão	**Configuração de Estado Desejado (Desired State Configuration - DSC)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma organização está provisionando 1.200 desktops virtuais em um ambiente de nuvem híbrida. A política de arquitetura de segurança exige que todas as instâncias sejam inicializadas a partir de uma baseline protegida e imutável, aderente ao CIS Benchmark Nível 1, com sensores de EDR pré-instalados e agentes de patch automático. Qual metodologia de implantação MELHOR atende a esse requisito garantindo reprodutibilidade automatizada?

A) Fornecer imagens padrão de fábrica aos usuários com checklists impressos e solicitar a configuração manual de políticas no primeiro login

B) Executar varreduras periódicas de vulnerabilidade com credenciais para detectar desvios e abrir chamados manuais para a equipe de suporte

C) Criar uma sequência automatizada de tarefas que provisiona uma imagem gold padronizada e protegida via CIS com ferramentas de gerenciamento

D) Exportar modelos de diretiva de segurança local para um compartilhamento de rede e executar scripts em lote administrativos sem controle central

QUESTÃO 2 · CENÁRIO DE EXAME

Após uma auditoria de conformidade, um engenheiro de segurança detecta desvio significativo de configuração (configuration drift) em 300 servidores Linux, incluindo acesso root por SSH, umask permissivo e firewalls locais desativados. A equipe exige uma solução automatizada que detecte continuamente desvios e imponha a baseline aprovada do CIS Linux Benchmark. Qual ferramenta e metodologia MELHOR atendem a esse objetivo?

A) Implantar playbooks do Ansible com tarefas idempotentes baseadas no CIS Benchmark executadas em um cronograma recorrente de orquestração

B) Agendar tarefas cron individuais em cada servidor para rodar scripts bash não auditados armazenados nos diretórios dos administradores locais

C) Realizar sessões periódicas manuais de auditoria via SSH para verificar arquivos de configuração e editar manualmente o sshd_config quando alertado

D) Configurar sensores de detecção de intrusão de rede que inspecionam conexões administrativas de SSH e apenas registram alertas de login root

QUESTÃO 3 · CENÁRIO DE EXAME

Após a transição para trabalho híbrido permanente, centenas de funcionários remotos raramente conectam seus laptops corporativos Windows à rede física ou à VPN da empresa. A equipe de segurança precisa aplicar e atualizar políticas obrigatórias de baseline—incluindo criptografia BitLocker, complexidade de senhas e patches automáticos—pela Internet pública. Qual plataforma de gerenciamento MELHOR atende a esses requisitos?

A) Distribuir scripts PowerShell assinados por e-mail e solicitar que os usuários remotos executem os comandos com privilégios administrativos elevados

B) Implantar o Microsoft Intune como solução em nuvem de gerenciamento de dispositivos móveis (MDM) para aplicar e impor configurações de baseline

C) Depender exclusivamente de Group Policy Objects (GPOs) do Active Directory local que exigem conexão física ou VPN à rede corporativa para atualizar

D) Configurar regras locais de firewall do Windows Defender em um laptop de teste e orientar usuários remotos a espelhar manualmente as configurações

QUESTÃO 4 · CENÁRIO DE EXAME

Um administrador de segurança em uma instituição bancária está configurando a baseline de proteção do sistema operacional para estações de atendimento e servidores de banco de dados que hospedam registros financeiros críticos. O administrador precisa equilibrar a usabilidade dos caixas com a máxima redução de superfície de ataque nos servidores de banco de dados. Qual estratégia aplica CORRETAMENTE os perfis do CIS Benchmark?

A) Aplicar o perfil CIS Benchmark Nível 2 em todas as estações de trabalho dos caixas enquanto desativa qualquer baseline nos servidores de banco de dados

B) Criar uma baseline personalizada internamente sem consultar padrões reconhecidos de mercado para evitar questionamentos de auditores externos

C) Configurar as estações de trabalho dos caixas com definições padrão de fábrica e aplicar o CIS Benchmark Nível 1 unicamente em roteadores de borda

D) Implantar o perfil CIS Benchmark Nível 1 nas estações para manter usabilidade e aplicar o rigoroso perfil CIS Benchmark Nível 2 nos servidores críticos

QUESTÃO 5 · CENÁRIO DE EXAME

Um administrador de rede Windows precisa importar as baselines de segurança recomendadas pela Microsoft e aplicá-las de forma consistente em 5.000 estações e servidores integrados ao domínio. O administrador deve garantir que as definições não possam ser sobrescritas por usuários locais e que a conformidade seja monitorada centralmente via Active Directory. Qual mecanismo deve ser implantado?

A) Importar os modelos administrativos ADMX das Microsoft Security Baselines e vincular Group Policy Objects (GPOs) nas Unidades Organizacionais (OUs)

B) Distribuir arquivos de exportação de registro (.reg) por anexo de e-mail e orientar funcionários a mesclar as chaves no registro de seus usuários locais

C) Configurar manualmente a Diretiva de Segurança Local (secpol.msc) em cada servidor durante janelas agendadas de manutenção em todas as filiais

D) Criar um script de inicialização em lote que executa comandos netsh não autenticados para configurar firewalls locais sem validação central

QUESTÃO 6 · CENÁRIO DE EXAME

Um auditor de segurança precisa verificar se 10.000 endpoints híbridos seguem rigorosamente as diretrizes obrigatórias de endurecimento (hardening) sem depender de entrevistas subjetivas ou inspeções manuais. A empresa exige um formato padronizado e automatizado que gere pontuações de conformidade estruturadas contra benchmarks reconhecidos. Qual padrão e protocolo o auditor deve exigir?

A) Consultas SNMPv2c com strings de comunidade pública executadas em switches e roteadores de rede fora do horário comercial de operação

B) Encaminhadores de syslog enviando registros em texto simples para um servidor local de arquivos sem correlação central ou normalização de dados

C) Scanners compatíveis com Security Content Automation Protocol (SCAP) utilizando benchmarks em formato XCCDF para auditoria de configuração

D) Disparos periódicos de pacotes ICMP echo e varreduras TCP syn para checar se os hosts respondem a testes básicos de conectividade perimetral

QUESTÃO 7 · CENÁRIO DE EXAME

Uma equipe de desenvolvimento de software em saúde está construindo um portal de pacientes em contêineres gerenciados pelo Kubernetes. O arquiteto de segurança exige que os nós e as imagens de contêiner sigam o princípio de infraestrutura imutável e mantenham uma baseline segura e auditada. Qual prática MELHOR atende a esse requisito?

A) Permitir que desenvolvedores acessem contêineres de produção diretamente por SSH para aplicar patches no sistema e alterar arquivos de configuração

B) Desativar agentes de segurança dentro dos contêineres para reduzir consumo de memória e executar todas as imagens com permissão de usuário root

C) Permitir que os contêineres façam download e compilação dinâmica de pacotes em repositórios públicos da Internet durante o boot dos pods

D) Construir imagens gold reforçadas via pipelines de CI/CD, realizar verificação de vulnerabilidades e substituir pods em vez de corrigi-los em execução

QUESTÃO 8 · CENÁRIO DE EXAME

Um hospital deve assegurar que 800 estações médicas com acesso a Dados Protegidos de Saúde (ePHI) atendam às salvaguardas de segurança da HIPAA. As máquinas devem impor bloqueio automático de tela, impedir dispositivos USB não autorizados, exigir MFA e executar EDR em tempo real. Qual abordagem MELHOR estabelece e mantém essa baseline segura?

A) Confiar que a equipe de saúde realize o bloqueio manual da tela e desconecte pendrives ao se afastar dos leitos e consultórios médicos

B) Provisionar os endpoints com imagem gold padronizada e protegida via CIS, aplicando políticas centralizadas via Intune ou GPOs do Active Directory

C) Instalar antivírus doméstico em cada máquina e conceder permissão para técnicos locais adicionarem exceções de portas e armazenamento

D) Autorizar que os profissionais conectem seus laptops pessoais na VLAN clínica sem registro prévio na plataforma corporativa de gerenciamento

QUESTÃO 9 · CENÁRIO DE EXAME

Durante uma investigação de resposta a incidentes, os analistas do SOC descobrem que um administrador local comprometeu a segurança ao desativar o serviço de EDR, pausar a proteção em tempo real do antivírus e abrir portas no firewall. Qual controle corporativo MELHOR impede que administradores desativem proteções e assegura recuperação automática?

A) Ativar proteção contra adulteração (tamper protection) nos agentes, restringir privilégios locais e usar ferramentas de orquestração para autocorreção

B) Conceder acesso de administrador total a todos os funcionários enviando comunicados semanais pedindo que não desativem os softwares de segurança

C) Reinstalar o sistema operacional manualmente a partir de mídias físicas toda vez que um usuário alterar um parâmetro de configuração local

D) Desativar a ingestão de logs no SIEM para eliminar a fadiga de alertas sempre que algum administrador pausar ferramentas de monitoramento

QUESTÃO 10 · CENÁRIO DE EXAME

Uma organização está elaborando a baseline segura para servidores web públicos posicionados na DMZ em conformidade com o princípio da menor funcionalidade (least functionality). Qual combinação de ações MELHOR reflete esse princípio de endurecimento de baseline?

A) Instalar compiladores de código, habilitar serviços de FTP e manter scripts administrativos de exemplo nos servidores web públicos

B) Liberar todas as portas TCP e UDP nos firewalls locais para evitar o bloqueio de eventuais recursos que desenvolvedores queiram testar

C) Habilitar protocolos legados como SMBv1 e Telnet para acesso remoto mantendo as credenciais de fábrica do banco de dados sem senha

D) Desativar serviços não utilizados, remover scripts de exemplo, fechar portas desnecessárias, remover compiladores e exigir apenas TLS 1.3

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Criar uma sequência automatizada de tarefas que provisiona uma imagem gold padronizada e protegida via CIS com ferramentas de gerenciamento

A implantação de uma imagem gold (golden image) padronizada e reforçada conforme o CIS Benchmark Nível 1 por meio de orquestração automatizada (SCCM, Intune ou Ansible) assegura baselines idênticas, auditáveis e imutáveis em toda a infraestrutura corporativa. A configuração manual pelos usuários (A) introduz inconsistências graves e falhas operacionais; a varredura de vulnerabilidades (B) é reativa e não atua na construção da baseline inicial; o uso de scripts em lote não gerenciados em rede (D) não possui controle de versão nem garantia de aplicação uniforme.

Questão 2: Alternativa A — Implantar playbooks do Ansible com tarefas idempotentes baseadas no CIS Benchmark executadas em um cronograma recorrente de orquestração

Ferramentas de gerenciamento de configuração como o Ansible utilizam playbooks idempotentes para auditar o estado real do sistema contra as diretrizes do CIS Benchmark, corrigindo automaticamente qualquer desvio de configuração (drift) sem intervenção humana. Scripts cron locais (B) não possuem governança central nem trilhas de auditoria; inspeções manuais por SSH (C) são ineficientes e sujeitas a erros humanos; sensores IDS de rede (D) realizam apenas monitoramento passivo de tráfego e não possuem capacidade de alterar parâmetros do sistema operacional.

Questão 3: Alternativa B — Implantar o Microsoft Intune como solução em nuvem de gerenciamento de dispositivos móveis (MDM) para aplicar e impor configurações de baseline

O Microsoft Intune é uma solução de MDM/UEM nativa em nuvem que distribui e fiscaliza baselines de segurança diretamente pela Internet, ideal para frotas remotas sem dependência de controladores de domínio locais ou túneis VPN permanentes. O envio de scripts por e-mail (A) depende de ação do usuário e carece de governança; as GPOs locais (C) exigem contato direto com a rede interna para sincronização; a configuração manual pelos usuários (D) é totalmente vulnerável a erros e desvios.

Questão 4: Alternativa D — Implantar o perfil CIS Benchmark Nível 1 nas estações para manter usabilidade e aplicar o rigoroso perfil CIS Benchmark Nível 2 nos servidores críticos

O perfil CIS Benchmark Nível 1 foca em endurecimento essencial com baixo impacto operacional, ideal para estações de trabalho de usuários finais; já o perfil Nível 2 aplica controles de defesa em profundidade altamente restritivos para servidores de backend e ambientes de alto risco onde a segurança sobrepõe a facilidade de uso. Aplicar Nível 2 em estações comuns (A) causa indisponibilidade de ferramentas diárias; baselines proprietárias não homologadas (B) falham em auditorias; padrões de fábrica (C) mantêm portas e serviços inseguros.

Questão 5: Alternativa A — Importar os modelos administrativos ADMX das Microsoft Security Baselines e vincular Group Policy Objects (GPOs) nas Unidades Organizacionais (OUs)

As Microsoft Security Baselines fornecem modelos administrativos ADMX prontos e testados para integração com o Active Directory, permitindo que GPOs vinculadas a OUs imponham configurações de segurança institucionais que se sobrepõem a privilégios locais e mantêm a padronização contínua. Arquivos .reg avulsos (B) dependem da ação de usuários e podem ser revertidos; a edição manual via secpol.msc (C) é inviável em 5.000 hosts; scripts em lote (D) não oferecem gerenciamento de conformidade.

Questão 6: Alternativa C — Scanners compatíveis com Security Content Automation Protocol (SCAP) utilizando benchmarks em formato XCCDF para auditoria de configuração

O padrão SCAP (Security Content Automation Protocol) e os arquivos de benchmark XCCDF estruturam a automação de conformidade de segurança, permitindo escanear milhares de sistemas operacionais e emitir notas formais de aderência às diretrizes do CIS ou DISA STIGs. O SNMPv2c (A) é um protocolo inseguro de gerência de hardware de rede; o syslog simples (B) gera registros de eventos mas não compara configurações contra baselines; varreduras de portas e ping (D) avaliam apenas disponibilidade de rede.

Questão 7: Alternativa D — Construir imagens gold reforçadas via pipelines de CI/CD, realizar verificação de vulnerabilidades e substituir pods em vez de corrigi-los em execução

A infraestrutura imutável preconiza que contêineres e instâncias em produção nunca sofram modificações em tempo de execução; qualquer atualização de baseline deve ser incorporada na imagem gold por meio do pipeline de CI/CD, gerando um novo artefato testado que substitui os contêineres anteriores. O acesso SSH para alterações diretas em produção (A) gera desvio de configuração e quebra a rastreabilidade; executar como root (B) viola o princípio do menor privilégio; baixar código na inicialização (C) expõe a ataques na cadeia de suprimentos.

Questão 8: Alternativa B — Provisionar os endpoints com imagem gold padronizada e protegida via CIS, aplicando políticas centralizadas via Intune ou GPOs do Active Directory

O uso de imagens gold padronizadas com configurações reforçadas (CIS Benchmark) combinadas com a aplicação centralizada de políticas via GPO ou Intune garante a execução inegociável dos controles da HIPAA (bloqueio automático de sessão, bloqueio de portas USB e EDR ativo). Depender de procedimentos manuais humanos (A) gera brechas graves de conformidade; antivírus doméstico com exceções locais (C) impede a visibilidade do SOC; dispositivos pessoais sem gestão (D) representam risco crítico de vazamento de dados.

Questão 9: Alternativa A — Ativar proteção contra adulteração (tamper protection) nos agentes, restringir privilégios locais e usar ferramentas de orquestração para autocorreção

A proteção contra adulteração (tamper protection) impede que mesmo administradores locais desativem ou manipulem serviços vitais de segurança como EDR e antivírus, enquanto a aplicação de privilégios mínimos evita concessões desnecessárias de root/admin. Complementarmente, ferramentas de orquestração detectam o drift e restauram a baseline imediatamente. Comunicados informais (B) não oferecem barreira técnica; reinstalações manuais (C) são ineficientes; desativar logs (D) anula a capacidade de detecção do SOC.

Questão 10: Alternativa D — Desativar serviços não utilizados, remover scripts de exemplo, fechar portas desnecessárias, remover compiladores e exigir apenas TLS 1.3

O princípio da menor funcionalidade (least functionality) estabelece que uma máquina deve executar exclusivamente os serviços necessários para cumprir sua função de negócio. Em servidores web expostos, isso requer desabilitar serviços supérfluos, fechar portas dispensáveis, expurgar scripts padrão e utilitários de compilação (que facilitam escalonamento de privilégios após invasão) e impor cifras fortes (TLS 1.3). Manter compiladores e FTP (A), liberar todas as portas (B) e ativar Telnet/SMBv1 (C) criam vulnerabilidades severas de segurança.